COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.5 · Operating System Security

Mestre CyberSec · **Aula 4.5 — Operating System Security** (3:22) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: AD (Active Directory: contas/group/GPO do Windows); Group Policy (deploy de política em massa); SELinux (MAC no Linux — cada processo só o que precisa); patch baseline; disable contas orfãs.

💡 Highlights que a prova CompTIA cobra

- Active Directory: o diretório corporativo Windows
- SELinux: MAC no Linux (mais rigoroso que root)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'centralized identity management in Windows'=Active Directory

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.5 — Operating System Security)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Active Directory (AD)

Serviço de diretório centralizado da Microsoft que gerencia usuários, grupos, computadores e recursos em um ambiente de domínio Windows através de um banco de dados hierárquico.

⚠ ***Armadilha CompTIA:*** *If the question mentions 'centralized identity management in Windows' or 'single sign-on for corporate resources' — the answer is Active Directory. Do NOT confuse with LDAP, which is only the protocol AD uses.*

• Objeto de Política de Grupo (GPO)

Uma coleção de configurações de segurança e configuração que podem ser aplicadas em massa a usuários e computadores dentro de um domínio Active Directory.

⚠ ***Armadilha CompTIA:*** *Exam trigger: 'deploy password policies or restrictions to many machines in a Windows domain' = GPO. GPO works ONLY with AD — without AD, there is no GPO.*

• SELinux (Linux com Segurança Aprimorada)

Um módulo de segurança do kernel Linux que implementa Controle de Acesso Mandatório (MAC), restringindo cada processo apenas às permissões mínimas necessárias.

⚠ ***Armadilha CompTIA:*** *Exam trigger: 'MAC on Linux' or 'process-level least privilege beyond root' = SELinux. Do NOT confuse with AppArmor (also Linux MAC, but different framework — Debian/Ubuntu default).*

• Controle de Acesso Mandatório (MAC)

Modelo de controle de acesso onde o sistema operacional impõe permissões com base em rótulos e políticas de segurança — o usuário não pode alterar permissões, nem mesmo como root.

⚠ ***Armadilha CompTIA:*** *MAC vs DAC: in DAC the owner decides; in MAC the OS/admin policy decides. SELinux = MAC, NTFS permissions = DAC. Exam always tests this distinction.*

• Baseline de Patches (N/A)

Conjunto documentado de atualizações aprovadas e padrões de configuração que define a postura mínima de segurança que todos os sistemas devem atender antes de entrar em produção.

⚠ ***Armadilha CompTIA:*** *Exam trigger: 'minimum configuration standard for new systems' or 'reference point for vulnerability scanning' = patch baseline. Often paired with CIS/NIST benchmarks on the exam.*

• Conta Órfã (N/A)
Conta de usuário não utilizada que permanece ativa após o funcionário ter saído da organização, criando um risco de segurança se for comprometida por atacantes.

⚠️ ***Armadilha CompTIA:*** *Exam answer is ALWAYS 'disable or remove'. Never leave orphaned accounts active. Triggers: 'former employee', 'unused account', 'access review' — best practice is disable first, then delete.*

• Controle de Acesso Discricionário (DAC)
Modelo de controle de acesso onde o dono do recurso decide quem tem permissões — modelo padrão usado nas permissões de arquivo Linux/Windows e NTFS.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'owner controls permissions' = DAC. NTFS permissions and chmod are DAC. If the question mentions 'the system enforces permissions regardless of owner' — that's MAC.*

• Protocolo Leve de Acesso a Diretório (LDAP)
Protocolo usado para consultar e gerenciar serviços de diretório, como o Active Directory, para autenticação centralizada e buscas de recursos.

⚠️ ***Armadilha CompTIA:*** *LDAP is the protocol; Active Directory is the directory service that USES LDAP. Secure version = LDAPS (port 636). Do not answer 'AD' when the question specifically asks about the protocol.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 SELinux & AppArmor (Mandatory Access Control em Nível de Kernel)

🏠 **Analogia Intuitiva:** Imagine que o servidor web é um cozinheiro em um restaurante de luxo. Num sistema comum sem proteção avançada, se um ladrão render o cozinheiro com uma faca no pescoço (explorar uma vulnerabilidade de software no Apache), o cozinheiro pode ser forçado a abrir o cofre do escritório da gerência ou entregar a chave do carro do dono. Com SELinux/AppArmor ativado, o cozinheiro opera dentro de uma cabine de vidro blindado com luvas embutidas na bancada: ele só tem alcance físico aos tomates e às panelas. Mesmo que o cozinheiro seja completamente dominado por um criminoso, as leis físicas da cabine o impedem de tocar em qualquer gaveta fora da cozinha.

🔍 **Causa Raiz / Por que foi criado:** Serviços e programas de rede frequentemente contêm falhas de corrupção de memória ou injeção. Quando comprometidos, se estiverem rodando com permissões tradicionais discricionárias (DAC), o invasor ganha todos os privilégios daquele usuário no sistema todo.

🛡️ **Visão do Auditor de GRC:** O auditor fiscaliza se o SELinux está em modo 'Enforcing' (e não 'Permissive' ou 'Disabled') em servidores de produção; audita perfis AppArmor ativos para daemons expostos e inspeciona logs de violações de AVC (Access Vector Cache) no Syslog.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Linux kernel security module enforcing mandatory access control on processes' = SELinux ou AppArmor. Pegadinha clássica: 'Permissive mode' apenas avisa/loga no audit.log sem bloquear a ação; 'Enforcing mode' ativamente bloqueia e loga a violação.

📌 Controle de Contas de Usuário (UAC - User Account Control) & Elevação de Privilégios

🏠 **Analogia Intuitiva:** O UAC funciona como a porta blindada com interfone da sala da diretoria em uma empresa. Mesmo que o diretor presidente esteja caminhando pelos corredores vestindo jeans e camiseta (sessão comum de usuário), para entrar no cofre e assinar um cheque de cem mil dólares (instalar um driver ou alterar o registro do Windows), a tela do computador escurece e ele precisa passar o crachá biométrico ou autorizar explicitamente no interfone. Nenhum malware escondido na mochila dele consegue abrir o cofre de fininho pelas costas dele.

🔍 **Causa Raiz / Por que foi criado:** Nos sistemas legados, os colaboradores operavam diariamente logados como Administradores locais irrestritos. Qualquer clique em executável malicioso ou site comprometido herdava automaticamente direitos de root/admin para destruir o sistema operacional.

🛡️ **Visão do Auditor de GRC:** Fiscalização de políticas de grupo (GPO) impondo UAC no nível máximo 'Always notify'; proibição formal de direitos de administrador local permanente para usuários finais e auditoria de logs de eventos de elevação de privilégio (Event ID 4672).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Windows feature that presents a secure desktop prompt requesting elevation confirmation before administrative tasks execute' = UAC (User Account Control).

📌 Hardening de SO & Redução da Superfície de Ataque (Attack Surface Reduction)

🏠 **Analogia Intuitiva:** Quando você aluga uma sala comercial para abrir uma agência de custódia de diamantes, a primeira medida é trocar todas as fechaduras genéricas da construtora (senhas padrão), emparedar portas de fundos e janelas que não serão utilizadas (fechar portas e desativar serviços não utilizados como Telnet e SMBv1) e recolher as cópias de chaves que estavam com os pintores (remover contas Guest e usuários padrão de teste). Quanto menos portas e janelas existirem no imóvel, menos pontos fracos os ladrões terão para arrombar.

🔍 **Causa Raiz / Por que foi criado:** Sistemas operacionais saem de fábrica repletos de utilitários, drivers de impressora, compartilhamentos de rede abertos e servidores web de teste para maximizar a comodidade do usuário leigo, mas cada um desses componentes é uma porta aberta para invasores.

🛡️ **Visão do Auditor de GRC:** Adoção obrigatória de guias de configuração segura reconhecidos internacionalmente (CIS Benchmarks ou DISA STIGs) na criação de imagens padrão (Golden Images); auditoria automatizada contínua com scanners de vulnerabilidade e configuração.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'disabling unneeded services, uninstalling unused software, changing default credentials, and renaming administrator accounts' = Operating System Hardening / Attack Surface Reduction.

📌 Gestão de Patches de SO & Ciclo de Atualizações (Patch Cadence)

🏠 **Analogia Intuitiva:** Pense nos patches como reparos estruturais urgentes na fuselagem de um navio em alto-mar. Quando o estaleiro descobre que um modelo de parafuso tem uma fissura que pode quebrar sob pressão (vulnerabilidade recém-descoberta), ele envia parafusos de titânio reforçados sob medida para substituir os defeituosos. Se o capitão do navio adiar a troca por preguiça de parar os motores por 20 minutos, o casco arrebenta na primeira tempestade.

🔍 **Causa Raiz / Por que foi criado:** Sistemas operacionais contêm dezenas de milhões de linhas de código humano e sempre terão falhas. Assim que o fabricante publica uma correção de segurança, os criminosos realizam engenharia reversa do patch para atacar quem ainda não instalou.

🛡️ **Visão do Auditor de GRC:** Auditoria do processo formal de Gestão de Mudanças (CAB): testes obrigatórios prévios em ambiente de homologação (Staging/Sandbox), SLA estrito de aplicação de patches críticos (ex: até 72 horas para vulnerabilidades exploradas ativamente) e plano de rollback validado.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'applying vendor updates to eliminate vulnerabilities while minimizing unexpected system crashes' = Patch Management. Pegadinha: nunca aplicar patches diretamente em produção sem validação prévia em sandbox/staging.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Processos Linux confinados no kernel com base em políticas e rótulos de controle mandatório	**SELinux / AppArmor**
Tela do Windows escurece exigindo confirmação explícita para modificar arquivos de sistema ou instalar softwares	**Controle de Contas de Usuário (UAC)**
Desativação de serviços desnecessários, fechamento de portas de rede não utilizadas e remoção de contas padrão	**Hardening de SO / Redução da Superfície de Ataque**
Modelo padronizado e blindado de sistema operacional usado para clonar novas máquinas virtuais com segurança	**Imagem Base Segura (Golden Image / Baseline)**
Modo operacional do SELinux que gera logs e alertas de violação de acesso mas não bloqueia a execução	**Modo Permissivo do SELinux (Permissive Mode)**
Prática de segurança que aplica correções de vulnerabilidades após homologação controlada em ambiente de testes	**Gestão de Patches (Patch Management)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Durante uma revisão trimestral de acessos em um hospital, a equipe de segurança descobre 14 contas de usuário do Active Directory pertencentes a prestadores de serviço cujos contratos terminaram há mais de 90 dias. As contas ainda estão habilitadas e permanecem em grupos privilegiados. A gerência quer reduzir imediatamente o risco relacionado a identidades. Qual ação a equipe de segurança deve tomar PRIMEIRO?

A) Redefinir as senhas das contas e exigir autenticação multifator no próximo logon em todos os endpoints corporativos gerenciados

B) Converter as contas em contas de serviço compartilhadas para tarefas administrativas do departamento mantendo telemetria e monitoramento contínuos

C) Desabilitar as contas, remover suas associações a grupos privilegiados e preservá-las para retenção de auditoria conforme a política.

D) Mover as contas para uma nova OU e aplicar uma GPO que as oculte da lista de endereços em todos os clusters híbridos locais e em nuvem

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa com 1.200 estações de trabalho Windows precisa impor bloqueio de tela após 10 minutos de inatividade e exigência de senha de 12 caracteres para todos os usuários de domínio. Os administradores querem que as configurações sejam aplicadas de forma consistente e automática, inclusive em novos computadores. Qual solução MELHOR atende ao requisito?

A) Criar e vincular um Objeto de Política de Grupo ao domínio ou às OUs apropriadas.

B) Configurar a Política de Segurança Local em cada estação de trabalho apenas durante a criação da imagem.

C) Implantar um script de logon que altera o registro no primeiro logon de cada usuário.

D) Habilitar o modo enforcing do SELinux nos controladores de domínio sem interromper a disponibilidade das cargas de produção

QUESTÃO 3 · CENÁRIO DE EXAME

Um servidor web Linux hospeda vários sites públicos. Após a divulgação de uma vulnerabilidade no serviço web, a equipe de segurança quer limitar os danos caso o serviço seja explorado, de modo que o processo httpd possa acessar apenas seu conteúdo web e as portas de rede necessárias, mesmo que um invasor obtenha execução de código. Qual controle de segurança MELHOR atende a esse requisito?

A) Definir as permissões do diretório de conteúdo web como 777 para que o processo não falhe eliminando pontos únicos de falha operacional

B) Configurar o SELinux no modo enforcing com uma política targeted e contextos de arquivo/booleans corretos.

C) Implementar controle de acesso discricionário tornando a conta do serviço web proprietária de todos os arquivos.

D) Usar iptables para permitir apenas tráfego de entrada TCP 80 e 443 para o servidor aplicando menor privilégio e reduzindo superfícies de ataque

QUESTÃO 4 · CENÁRIO DE EXAME

Uma organização tem 300 servidores Windows. A aplicação de patches é inconsistente: alguns servidores instalam atualizações automaticamente, outros estão meses atrasados, e administradores aprovam atualizações manualmente de formas diferentes por equipe. Os auditores exigem uma lista padronizada de patches aprovados e um processo de implantação repetível. Qual ação MELHOR estabelece uma linha de base de patches?

A) Habilitar atualizações automáticas em todos os servidores e deixar cada administrador reiniciar quando for conveniente em todos os clusters híbridos locais e em nuvem

B) Criar uma GPO que desabilite o Windows Update em todos os servidores para impedir patches não aprovados sem interromper a disponibilidade das cargas de produção

C) Executar um script semanal que baixa todas as atualizações disponíveis e as instala sem testes aplicando menor privilégio e reduzindo superfícies de ataque

D) Definir uma linha de base de patches aprovada em uma plataforma central de gerenciamento e implantá-la em grupos de servidores conforme um cronograma.

QUESTÃO 5 · CENÁRIO DE EXAME

O departamento financeiro usa uma pasta compartilhada em um servidor de arquivos Windows. Atualmente, cada funcionário do financeiro é adicionado individualmente na ACL da pasta, e quando alguém muda de função, permissões frequentemente permanecem. A equipe de segurança quer simplificar a administração e impor privilégio mínimo com base na função. O que eles devem fazer?

A) Criar um grupo de segurança do AD para o financeiro, atribuir permissões de pasta ao grupo e gerenciar a associação de usuários.

B) Criar um grupo de distribuição do AD para o financeiro e atribuir permissões de pasta ao grupo aplicando menor privilégio e reduzindo superfícies de ataque

C) Colocar todos os usuários do financeiro no grupo Domain Admins e então remover suas entradas ACL individuais através de pipelines automatizados de configuração

D) Configurar uma GPO que mapeie a pasta compartilhada para todos os usuários autenticados assegurando conformidade rigorosa de retenção de logs

QUESTÃO 6 · CENÁRIO DE EXAME

Um aplicativo de RH personalizado precisa autenticar funcionários no Active Directory da empresa. A política de segurança proíbe armazenar senhas de funcionários no banco de dados do aplicativo e exige que a desabilitação centralizada de contas tenha efeito imediato. Qual abordagem de integração MELHOR atende a esses requisitos?

A) Criar contas locais no aplicativo e sincronizar senhas noturnamente a partir do Active Directory aplicando menor privilégio e reduzindo superfícies de ataque

B) Armazenar hashes de senha do Active Directory em um arquivo texto acessível ao aplicativo através de pipelines automatizados de configuração

C) Configurar o aplicativo para autenticar usuários por meio de consultas/binds LDAP(S) ao Active Directory.

D) Exigir que os usuários entrem com uma conta de aplicativo compartilhada gerenciada pela equipe de RH utilizando perfis padronizados de automação de segurança

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa quer bloquear dispositivos USB de armazenamento em massa nos computadores usados pelo departamento financeiro, mas permitir teclados e mouses USB. Os computadores do financeiro estão em uma OU dedicada, e a empresa usa sistemas Windows ingressados no domínio. Qual método é MAIS eficiente e aplicável?

A) Colocar cola física em todas as portas USB dos computadores do financeiro através de pipelines automatizados de configuração

B) Aplicar uma política de segurança local em cada computador do financeiro e pedir aos usuários que não conectem drives.

C) Configurar booleans do SELinux nas estações do financeiro para negar armazenamento USB.

D) Criar uma GPO vinculada à OU do financeiro que desabilite o acesso a armazenamento removível.

QUESTÃO 8 · CENÁRIO DE EXAME

Em um servidor Linux, desenvolvedores são proprietários de arquivos em um diretório compartilhado de projeto. A segurança descobre que um desenvolvedor pode alterar permissões de um arquivo sensível e conceder leitura a outros usuários, mesmo que o arquivo contenha dados regulamentados. A equipe de segurança quer que o sistema operacional imponha regras de acesso que proprietários de arquivos não possam sobrepor. Qual controle MELHOR fornece isso?

A) Permissões padrão de controle de acesso discricionário do UNIX.

B) Uma política de controle de acesso obrigatório do SELinux.

C) Listas de controle de acesso que concedem propriedade ao desenvolvedor.

D) Uma regra sudoers permitindo que desenvolvedores gerenciem permissões de arquivos.

QUESTÃO 9 · CENÁRIO DE EXAME

Uma auditoria em um servidor Linux de aplicação encontra uma conta de serviço local chamada appsvc. O aplicativo que ela suportava foi desativado há seis meses, mas a conta ainda tem senha válida, uma chave SSH autorizada e shell Bash. Qual ação o administrador deve tomar para reduzir o risco?

A) Bloquear a conta, remover suas chaves SSH, definir o shell como nologin e excluí-la se não houver dependência.

B) Alterar a senha e armazená-la no cofre de senhas da equipe para uso futuro prevenindo desvios não autorizados de configuração nos nós

C) Adicionar a conta ao arquivo sudoers para que futuros administradores possam solucionar problemas em todos os endpoints corporativos gerenciados

D) Alterar o UID da conta e deixar seus arquivos inalterados mantendo telemetria e monitoramento contínuos

QUESTÃO 10 · CENÁRIO DE EXAME

Um servidor crítico de manufatura executa um aplicativo certificado pelo fornecedor. O fornecedor não certificou a atualização de segurança mais recente, mas a linha de base de patches da organização a exige. O servidor não pode ser desligado para testes neste trimestre. O que a equipe de segurança deve fazer?

A) Remover o servidor de toda aplicação de patches e monitoramento porque ele não pode ser atualizado prevenindo desvios não autorizados de configuração nos nós

B) Aplicar a atualização imediatamente sem testes e aceitar qualquer indisponibilidade do aplicativo em todos os endpoints corporativos gerenciados

C) Desabilitar o firewall do servidor para que o fornecedor possa aplicar remotamente um patch não aprovado mantendo telemetria e monitoramento contínuos

D) Documentar uma exceção temporária, aplicar controles compensatórios e rastrear o servidor em um grupo de patches separado até a certificação do fornecedor.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Desabilitar as contas, remover suas associações a grupos privilegiados e preservá-las para retenção de auditoria conforme a política.

Correta: Contas órfãs são risco grave porque permanecem habilitadas e privilegiadas depois que o usuário não deveria mais ter acesso. A primeira ação é desabilitá-las e remover associações a grupos privilegiados, preservando-as apenas conforme exigido para auditoria. Redefinir senha as mantém habilitadas; converter em conta compartilhada prejudica responsabilização; ocultar da lista não remove acesso.

Questão 2: Alternativa A — Criar e vincular um Objeto de Política de Grupo ao domínio ou às OUs apropriadas.

Correta: Objetos de Política de Grupo implantam e aplicam centralmente configurações de segurança do Windows em sistemas ingressados no domínio e podem ser aplicados a novos computadores colocados no domínio ou na OU vinculada. Política de Segurança Local afeta apenas a máquina local e pode não cobrir novos sistemas de forma confiável; scripts de logon são menos confiáveis e não são política de segurança real; SELinux é um mecanismo de controle de acesso obrigatório no Linux, não uma ferramenta de política AD no Windows.

Questão 3: Alternativa B — Configurar o SELinux no modo enforcing com uma política targeted e contextos de arquivo/booleans corretos.

Correta: SELinux é um sistema de controle de acesso obrigatório no Linux que confina processos como o httpd a tipos/domínios declarados e limita o que eles podem acessar mesmo após comprometimento. Definir permissões como 777 aumenta o risco; tornar a conta de serviço proprietária ainda é controle discricionário e amplo; iptables filtra tráfego de rede, mas não confina o acesso a arquivos e processos de um processo comprometido.

Questão 4: Alternativa D — Definir uma linha de base de patches aprovada em uma plataforma central de gerenciamento e implantá-la em grupos de servidores conforme um cronograma.

Correta: Uma linha de base de patches é um conjunto documentado de patches e configurações aprovados usado pelo gerenciamento central para implantar atualizações de forma consistente. Atualizações automáticas por servidor causam inconsistência; desabilitar o Windows Update impede correções de segurança; instalar todas as atualizações sem testes viola o controle de mudanças e pode interromper serviços.

Questão 5: Alternativa A — Criar um grupo de segurança do AD para o financeiro, atribuir permissões de pasta ao grupo e gerenciar a associação de usuários.

Correta: Grupos de segurança do AD são projetados para atribuição de permissões e simplificam o controle de acesso baseado em função. Grupos de distribuição são para e-mail e não podem ser usados para permissões de segurança; Domain Admins concede privilégio excessivo; mapear a pasta para todos os usuários autenticados concede acesso amplo demais.

Questão 6: Alternativa C — Configurar o aplicativo para autenticar usuários por meio de consultas/binds LDAP(S) ao Active Directory.

Correta: LDAP(S) permite que o aplicativo consulte e autentique no Active Directory sem armazenar senhas de funcionários. Sincronização noturna de senhas atrasa a desabilitação centralizada e armazena credenciais; armazenar hashes de senha é inseguro; uma conta de aplicativo compartilhada quebra a responsabilização e não impõe desabilitação centralizada imediata por usuário.

Questão 7: Alternativa D — Criar uma GPO vinculada à OU do financeiro que desabilite o acesso a armazenamento removível.

Correta: Uma GPO vinculada à OU do financeiro aplica centralmente restrições de dispositivo para todos os computadores atuais e futuros naquela OU. Cola física é impraticável e afeta todos os dispositivos USB; política local não é aplicada centralmente; SELinux é um controle Linux, não um mecanismo de política para estações Windows de domínio.

Questão 8: Alternativa B — Uma política de controle de acesso obrigatório do SELinux.

Correta: O controle de acesso obrigatório do SELinux impõe política independentemente da propriedade de arquivo e do DAC, então mesmo um proprietário não pode sobrepor negações do SELinux. Permissões UNIX padrão e ACLs são controles de acesso discricionário; uma regra sudoers aumenta a capacidade do desenvolvedor de alterar permissões.

Questão 9: Alternativa A — Bloquear a conta, remover suas chaves SSH, definir o shell como nologin e excluí-la se não houver dependência.

Correta: Esta é uma conta local órfã com credenciais ativas. A boa prática é remover o acesso bloqueando-a, removendo chaves SSH, definindo um shell não interativo e excluindo-a se não houver dependência. Manter a senha,

adicionar privilégios sudo ou alterar o UID deixa caminhos de acesso e viola o privilégio mínimo.

Questão 10: Alternativa D — Documentar uma exceção temporária, aplicar controles compensatórios e rastrear o servidor em um grupo de patches separado até a certificação do fornecedor.
Correta: Quando uma linha de base de patches não pode ser aplicada, a gestão formal de exceções com controles compensatórios e rastreamento é apropriada até que o fornecedor certifique a atualização. Remover patches e monitoramento aumenta o risco; aplicar uma atualização não testada pode interromper a manufatura crítica; desabilitar o firewall é inseguro.